

Cryptographic posture assessment

Synthetic lab PCAP

lab-legacy-clients-offer.pcap

Capture timestamp: 2026-10-04T12:00:00+00:00

Source SHA-256: 5d5963531009bae8b390307518574c806e5663da96f02bec596ece77daf7b614

Generated: 2026-10-05T13:52:46Z

MAIL SESSIONS	POSTURE	EVIDENCE GAPS
5	HIGH_RISK	5

SecureMailScope analyzed 5 observed IMAP/SMTP transport session(s) from capture 'lab-legacy-clients-offer.pcap'. 0 session(s) passed all assessed baseline checks, 2 required review, and 3 had critical transport risks. Significant transport weaknesses or obsolete cryptographic protocols were identified. The primary drivers of this assessment were: deprecated TLS protocols (TLS 1.0/1.1) were negotiated; legacy or non-AEAD cipher suites were utilized. AI-assisted anomaly prioritization evaluated 5 observed client profiles across 14 transport dimensions. 2 client(s) were prioritized for analyst attention based on relative statistical divergence.

Prioritized security findings

HIGH / FAIL / SMS-CERT-001

Certificate assessment: issues detected

Self-issued leaf certificate; explicit trust required

Evidence: Self-issued leaf certificate; explicit trust required

Recommendation: Renew invalid certificates, use modern keys, and supply an approved PEM trust store via SMS_TRUST_STORE for offline path validation. Check revocation separately.

References: RFC 5280, RFC 8446

[RULE] Recommended fix

1. Check the reported certificate issue against the intended hostname and capture time.
2. Renew expired certificates, correct names and intermediates, and use approved keys and signature algorithms as applicable.
3. Supply an approved PEM trust bundle for offline path validation. Assess revocation using separately obtained evidence; this tool makes no revocation requests.

HIGH / FAIL / SMS-TLSVER-001

Deprecated TLS Version (TLS 1.0)

Observed email session negotiated deprecated TLS 1.0 protocol, which is susceptible to known downgrade attacks and lacks modern authenticated encryption.

Evidence: Server selected deprecated protocol version TLS 1.0.

Recommendation: Disable TLS 1.0 on 198.51.100.25 and configure the mail server to require TLS 1.2 or TLS 1.3 as the minimum acceptable protocol version.

References: RFC 8996, NIST SP 800-52 Rev. 2

[RULE] Recommended fix

1. Inventory ClientHello offers and upgrade clients that cannot offer TLS 1.2 or newer.
2. Set a TLS 1.2 minimum on the affected service after staging tests and a rollback plan.
3. Check both mandatory and opportunistic TLS settings for the intended service.

Postfix 3.6+ (smtpd) / Review and test before applying

Example parameter values for authenticated submission only. Translate to per-service master.cf overrides where appropriate. Requires a working TLS certificate/key. Do not apply globally to a public port-25 relay.

```
smtpd_tls_security_level = encrypt
```

```
smtpd_tls_mandatory_protocols = >=TLSv1.2
```

HIGH / FAIL / SMS-CIPHER-001

Weak / Deprecated Cipher Suite (TLS_RSA_WITH_3DES_EDE_CBC_SHA)

The session negotiated weak or deprecated cipher suite TLS_RSA_WITH_3DES_EDE_CBC_SHA, which is vulnerable to cryptanalytic attacks.

Evidence: Negotiated cipher suite identifier: TLS_RSA_WITH_3DES_EDE_CBC_SHA.

Recommendation: Disable obsolete cipher suites (RC4, 3DES, DES, EXPORT, NULL) on the mail server and require modern AEAD suites (e.g., AES-GCM or ChaCha20-Poly1305).

References: RFC 7465, RFC 7540, NIST SP 800-52 Rev. 2

[RULE] Recommended fix

1. Upgrade the affected mail server and client TLS libraries.
2. Remove the identified weak suites from that service using its version-specific cipher configuration; prefer supported AEAD suites.
3. Test client compatibility and verify the newly selected cipher in a fresh capture.

MEDIUM / WARN / SMS-PFS-001

Static Key Exchange Without Forward Secrecy

The session negotiated a static RSA key exchange cipher suite lacking Perfect Forward Secrecy. Compromise of the server private key allows retroactive decryption of past sessions.

Evidence: Negotiated cipher suite TLS_RSA_WITH_AES_128_CBC_SHA uses static RSA key exchange without ephemeral parameters.

Recommendation: Configure the mail server to disable static RSA key exchange suites and prioritize ECDHE key exchange.

[RULE] Recommended fix

1. Prefer ephemeral ECDHE/DHE key exchange where supported; remove static RSA exchange after compatibility testing.
2. For TLS 1.3 inspect the selected key-share group; the cipher name alone does not prove forward secrecy.

MEDIUM / WARN / SMS-PFS-001

Static Key Exchange Without Forward Secrecy

The session negotiated a static RSA key exchange cipher suite lacking Perfect Forward Secrecy. Compromise of the server private key allows retroactive decryption of past sessions.

Evidence: Negotiated cipher suite TLS_RSA_WITH_3DES_EDE_CBC_SHA uses static RSA key exchange without ephemeral parameters.

Recommendation: Configure the mail server to disable static RSA key exchange suites and prioritize ECDHE key exchange.

References: RFC 8446, NIST SP 800-52 Rev. 2

[RULE] Recommended fix

1. Prefer ephemeral ECDHE/DHE key exchange where supported; remove static RSA exchange after compatibility testing.
2. For TLS 1.3 inspect the selected key-share group; the cipher name alone does not prove forward secrecy.

INFO / PASS / SMS-TLSVER-002

Modern TLS Version (TLS 1.3)

A currently accepted TLS protocol version (TLS 1.3) was observed.

Evidence: Server negotiated modern protocol version TLS 1.3.

Recommendation: Maintain current TLS version baseline and monitor for future cryptographic standard updates.

References: RFC 8446, NIST SP 800-52 Rev. 2

[RULE] Recommended fix

1. No change is required by this observed check. Maintain the baseline and re-check a fresh capture after configuration changes.

INFO / PASS / SMS-PFS-001

Forward Secrecy Supported

The TLS 1.3 ServerHello key_share indicates ephemeral key exchange; the cipher name alone does not establish this.

Evidence: TLS 1.3 ServerHello key_share observed: 29.

Recommendation: Continue enforcing ephemeral key exchanges (ECDHE) across all mail transport connections.

References: RFC 8446, NIST SP 800-52 Rev. 2

[RULE] Recommended fix

1. No change is required by this observed check. Maintain the baseline and re-check a fresh capture after configuration changes.

INFO / UNKNOWN / SMS-CERT-001

Certificate assessment: limited visibility

No server certificate is visible. TLS 1.3 encrypts certificates; a partial or resumed handshake may also omit them.

Evidence: No server certificate is visible. TLS 1.3 encrypts certificates; a partial or resumed handshake may also omit them.

Recommendation: Renew invalid certificates, use modern keys, and supply an approved PEM trust store via SMS_TRUST_STORE for offline path validation. Check revocation separately.

References: RFC 5280, RFC 8446

[RULE] Recommended fix

1. Collect the missing handshake or certificate evidence before deciding on a configuration change.
2. For encrypted TLS 1.3 certificates, obtain approved endpoint certificate evidence separately. Do not interpret missing evidence as a failure.

INFO / PASS / SMS-TLSVER-002

Modern TLS Version (TLS 1.2)

A currently accepted TLS protocol version (TLS 1.2) was observed.

Evidence: Server negotiated modern protocol version TLS 1.2.

Recommendation: Maintain current TLS version baseline and monitor for future cryptographic standard updates.

References: RFC 5246, NIST SP 800-52 Rev. 2

[RULE] Recommended fix

1. No change is required by this observed check. Maintain the baseline and re-check a fresh capture after configuration changes.

INFO / PASS / SMS-PFS-001

Forward Secrecy Supported

The negotiated cipher suite utilizes ephemeral key exchange (ECDHE/DHE), providing Perfect Forward Secrecy.

Evidence: Negotiated cipher suite TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 includes ephemeral key exchange.

Recommendation: Continue enforcing ephemeral key exchanges (ECDHE) across all mail transport connections.

References: RFC 8446, NIST SP 800-52 Rev. 2

[RULE] Recommended fix

1. No change is required by this observed check. Maintain the baseline and re-check a fresh capture after configuration changes.

Certificate assessment: limited visibility

No server certificate is visible. TLS 1.3 encrypts certificates; a partial or resumed handshake may also omit them.

Evidence: No server certificate is visible. TLS 1.3 encrypts certificates; a partial or resumed handshake may also omit them.

Recommendation: Renew invalid certificates, use modern keys, and supply an approved PEM trust store via SMS_TRUST_STORE for offline path validation. Check revocation separately.

References: RFC 5280, RFC 8446

[RULE] Recommended fix

1. Collect the missing handshake or certificate evidence before deciding on a configuration change.
2. For encrypted TLS 1.3 certificates, obtain approved endpoint certificate evidence separately. Do not interpret missing evidence as a failure.

INFO / PASS / SMS-TLSVER-002

Modern TLS Version (TLS 1.2)

A currently accepted TLS protocol version (TLS 1.2) was observed.

Evidence: Server negotiated modern protocol version TLS 1.2.

Recommendation: Maintain current TLS version baseline and monitor for future cryptographic standard updates.

References: RFC 5246, NIST SP 800-52 Rev. 2

[RULE] Recommended fix

1. No change is required by this observed check. Maintain the baseline and re-check a fresh capture after configuration changes.

INFO / UNKNOWN / SMS-CERT-001

Certificate assessment: limited visibility

No server certificate is visible. TLS 1.3 encrypts certificates; a partial or resumed handshake may also omit them.

Evidence: No server certificate is visible. TLS 1.3 encrypts certificates; a partial or resumed handshake may also omit them.

Recommendation: Renew invalid certificates, use modern keys, and supply an approved PEM trust store via SMS_TRUST_STORE for offline path validation. Check revocation separately.

References: RFC 5280, RFC 8446

[RULE] Recommended fix

1. Collect the missing handshake or certificate evidence before deciding on a configuration change.
2. For encrypted TLS 1.3 certificates, obtain approved endpoint certificate evidence separately. Do not interpret missing evidence as a failure.

Insufficient Cryptographic Evidence

TLS traffic was observed, but the available capture does not contain sufficient handshake evidence to determine the negotiated cipher suite.

Evidence: TLS traffic was observed, but the available capture does not contain sufficient handshake evidence to determine the negotiated cipher suite.

Recommendation: Capture network traffic from the initiation of the TCP session to include complete ClientHello and ServerHello handshake frames.

References: [SecureMailScope Evidence Guidelines](#)

[RULE] Recommended fix

1. Collect the missing handshake or certificate evidence before deciding on a configuration change.
2. For encrypted TLS 1.3 certificates, obtain approved endpoint certificate evidence separately. Do not interpret missing evidence as a failure.

INFO / UNKNOWN / SMS-CERT-001

Certificate assessment: limited visibility

No server certificate is visible. TLS 1.3 encrypts certificates; a partial or resumed handshake may also omit them.

Evidence: No server certificate is visible. TLS 1.3 encrypts certificates; a partial or resumed handshake may also omit them.

Recommendation: Renew invalid certificates, use modern keys, and supply an approved PEM trust store via SMS_TRUST_STORE for offline path validation. Check revocation separately.

References: [RFC 5280](#), [RFC 8446](#)

[RULE] Recommended fix

1. Collect the missing handshake or certificate evidence before deciding on a configuration change.
2. For encrypted TLS 1.3 certificates, obtain approved endpoint certificate evidence separately. Do not interpret missing evidence as a failure.

Session evidence and certificates

SMTP-STREAM-0: Client (192.0.2.21) -> Server (198.51.100.25)

SMTP / Direct TLS (Implicit) / TLS 1.3 / TLS_AES_256_GCM_SHA384

ServerHello frame: 6. Packets: 15. STARTTLS requested: False; accepted: False; ServerHello after upgrade: False.

INFO / [OBSERVED] Classical key exchange observed

Group: x25519. May be exposed to harvest-now-decrypt-later; this is an observation, not a vulnerability.

IMAP-STREAM-1: Client (192.0.2.22) -> Server (198.51.100.25)

IMAP / Direct TLS (Implicit) / TLS 1.2 / TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256

ServerHello frame: 21. Packets: 15. STARTTLS requested: False; accepted: False; ServerHello after upgrade: False.

INFO / [COVERAGE_GAP] Quantum readiness: UNKNOWN

Group: UNKNOWN. A recognized TLS 1.3 ServerHello key-share group is not visible. No readiness conclusion or failing check is produced.

CN=mail.sih.test

Issuer: CN=mail.sih.test. Key: RSA 2048. Signature hash: sha256.

Validity: 2026-06-26T00:00:00+00:00 to 2027-10-04T00:00:00+00:00. Capture frame: 21.

No explicit trust store supplied. Chain trust and revocation are not verified.

Certificate SHA-256: c2bc1829b1e82254840b43cd7b09cadf343785ebec29eb3086c9686746dbfbd

SMTP-STREAM-2: Client (192.0.2.23) -> Server (198.51.100.25)

SMTP / Direct TLS (Implicit) / TLS 1.0 / TLS_RSA_WITH_AES_128_CBC_SHA

ServerHello frame: 36. Packets: 9. STARTTLS requested: False; accepted: False; ServerHello after upgrade: False.

INFO / [COVERAGE_GAP] Quantum readiness: UNKNOWN

Group: UNKNOWN. A recognized TLS 1.3 ServerHello key-share group is not visible. No readiness conclusion or failing check is produced.

SMTP-STREAM-3: Client (192.0.2.24) -> Server (198.51.100.25)

SMTP / Direct TLS (Implicit) / TLS 1.2 / TLS_RSA_WITH_3DES_EDE_CBC_SHA

ServerHello frame: 45. Packets: 9. STARTTLS requested: False; accepted: False; ServerHello after upgrade: False.

INFO / [COVERAGE_GAP] Quantum readiness: UNKNOWN

Group: UNKNOWN. A recognized TLS 1.3 ServerHello key-share group is not visible. No readiness conclusion or failing check is produced.

SMTP-STREAM-4: Client (192.0.2.25) -> Server (198.51.100.25)

SMTP / UNKNOWN (Handshake not captured) / UNKNOWN / UNKNOWN / Not Captured

ServerHello frame: not captured. Packets: 7. STARTTLS requested: False; accepted: False; ServerHello after upgrade: False.

INFO / [COVERAGE_GAP] Quantum readiness: UNKNOWN

Group: UNKNOWN. A recognized TLS 1.3 ServerHello key-share group is not visible. No readiness conclusion or failing check is produced.

AI-assisted prioritization

Evaluated 5 observed client profile(s) across 14 transport dimensions. 2 client(s) surfaced for prioritized analyst review based on statistical behavioral divergence.

AI anomaly scores provide statistical prioritization relative to the observed capture fleet only. AI assessments never declare maliciousness or replace deterministic Phase 2 security findings.

Assessment boundaries

- TLS selections come from ServerHello; observing ServerHello does not prove handshake completion or successful delivery.
- TLS 1.3 certificates are encrypted. Chain validation requires visible certificates, observed SNI, capture time, and SMS_TRUST_STORE. Revocation is not checked.

- Capture SHA-256 and report hashes support integrity comparison, not source authentication or digital signatures.
- Analysis reflects strictly traffic captured and visible within the submitted packet capture window.
- Passive network observation cannot evaluate email clients or cryptographic capabilities absent from the capture.
- Incomplete TCP streams or truncated TLS handshakes in capture boundaries may limit full capability assessment.
- AI-assisted anomaly prioritization is relative strictly to the observed client population in this capture.
- AI anomaly engine abstains from statistical ranking when the comparison population is insufficient (minimum 5 observed clients).
- Encrypted application-layer email payload (message text, headers, attachments) is not decrypted.
- Hardening Impact Simulation results reflect passive capability evidence only and do not modify live servers.

Evidence integrity

Report digest: e92e1a1cc9db2122c1affab20f8dac1de9a03f3982626d79be989ea593a617c

Hashes detect changes only when compared with an independently retained reference. They are not digital signatures and do not authenticate the analyst or the capture origin.

Capture files can contain sensitive payloads and are processed locally by TShark. Temporary uploaded files are removed after analysis. Command arguments are discarded at the extraction boundary; generated investigations retain transport and certificate metadata rather than message bodies or authentication secrets. Reports may contain IP addresses, hostnames, and certificate identities. No network revocation lookup or cloud AI is used.